ZENTECH BİLİŞİM A.Ş. - BİLGİ GÜVENLİĞİ DENETİM RAPORU

Denetlenen Kurum: Zentech Bilişim A.Ş.

Denetim Konusu: BT Güvenlik Denetimi (Active Directory ve Ağ Altyapısı)

Denetim Tarihi: 16 Ağustos 2025

Denetçi: Necdet Emre Bayraktar (Bilgi Sistemleri Denetçisi Adayı)

1. Yönetici Özeti

Bu rapor, İstanbul merkezli, 70 çalışanı bulunan orta ölçekli yazılım geliştirme firması Zentech Bilişim A.Ş.'nin BT altyapısına ilişkin bilgi güvenliği denetim bulgularını içermektedir. Şirketin yazılı bir Bilgi Güvenliği Politikası ve Parola Politikası bulunmakta, IT personeli kritik cihazlarda güçlü parola kullandığını ve parola politikasının uygulandığını beyan etmektedir.

Ancak gerçekleştirilen kanıta dayalı inceleme sonucunda, switch üzerindeki root parolasının "admin123" olduğu ve tuzsuz SHA-1 hash'inin Hashcat ile kısa sürede kırılabildiği tespit edilmiştir. Domain Admins grubunda yönetici olmaması gereken kullanıcılar bulunmakta, Domain Controller üzerinde Guest hesabı parolasız olarak aktif durmakta, Audit Policy kapalı ve parola politikası GPO ile zorunlu kılınmamaktadır. Ayrıca kablosuz ağların VLAN yapısı belirsizdir ve ağ cihazlarının önemli bir kısmı güncelleme almayan eski sürümlerde çalışmaktadır.

Toplam 6 bulgu tespit edilmiştir: 3 Critical ve 3 High. Mevcut durum, yazılı politikaların uygulamaya yansımadığını ve tek bir zayıf parola ya da açık hesap üzerinden tüm domain ortamının ele geçirilebileceğini göstermektedir.

2. Denetim Kapsamı

Zentech Bilişim A.Ş.'nin BT altyapısı incelenmiştir. Denetime konu olan unsurlar şunlardır:

Bileşen	Detay
Active Directory	1 adet on-premise Domain Controller (DC01, zentech.local)
Sunucular	2 fiziksel sunucu
Switch (6 adet)	2x Cisco Catalyst 2960 (IOS 12.2), 2x TP-Link SG108E (web arayüzü), 1x Ubiquiti UniFi 24, 1x Zyxel eski model (güncelleme almıyor)
Kablosuz Ağ	2 Kablosuz Erişim Noktası (Wi-Fi AP)
VLAN	3 VLAN: Admin, Developer, Guest
Firewall	Cisco ASA 5505, ASA 8.2(5)

3. Denetim Amaçları

- Kullanıcı ve erişim yönetiminin şirket politikaları ile uyumluluğunu kontrol etmek.
- Ağ cihazları ve altyapı bileşenlerinin güvenlik durumunu incelemek.
- Bilgi Güvenliği Politikası ve Parola Politikası'nın uygulamaya yansıtılmasını değerlendirmek.
- Zafiyetlerin risklerini tespit ederek giderilmesi için öneriler sunmak.

4. Metodoloji

- Sistem yapılandırmalarının ve konfigürasyon dosyalarının gözden geçirilmesi.
- Switch üzerindeki /etc/shadow dosyasından alınan parola hash'inin Hashcat ile test edilmesi (etik şekilde, denetim kapsamında).
- Domain Controller üzerinde kullanıcı, grup (Domain Admins), Guest hesabı, Audit Policy ve GPO ayarlarının kontrolü.
- VLAN ve ağ segmentasyonunun değerlendirilmesi.
- Ağ cihazlarının model, işletim sistemi ve firmware sürümlerinin incelenmesi.
- Eksik bilgilerin tamamlanması için yönetime soruların yöneltilmesi (Ek-1).

Şirket politikalarında denetimde esas alınan başlıca kurallar şunlardır: kullanıcıların kendine özel kullanıcı adı ve parola ile oturum açması, hassas bilgilere yalnızca yetkili personelin erişmesi, USB bellek kullanımının onaya bağlı olması; parolaların en az 8 karakter olması, harf, rakam ve özel karakter içermesi, son 3 parolanın tekrar kullanılmaması, en fazla 90 gün geçerli olması ve 5 hatalı girişte hesabın kilitlenmesi.

5. Bulgular ve Değerlendirme

Bulgu 1 - Zayıf Parola Kullanımı

- **Eksiklik:** IT personeli güçlü parola kullandığını beyan etmesine rağmen, switch üzerindeki /etc/shadow dosyasında root kullanıcısının parolasının tuzsuz (unsalted) SHA-1 hash'i olarak tutulduğu (f865b53623b121fd34ee5426c792e5c33af8c227) ve bu hash'in Hashcat ile kısa sürede kırılarak parolanın "admin123" olduğu tespit edilmiştir. Parola, şirketin özel karakter zorunluluğu içeren Parola Politikası'na da aykırıdır.
- **Neden:** IT personelinin parola politikasına uymaması ve ağ cihazlarında parolaların zayıf bir hash yöntemiyle saklanması.
- **Etkisi:** Yetkisiz kişiler switch yapılandırmasını ele geçirerek ağ trafiğini yönlendirebilir, sniffing ve MITM saldırıları yapabilir.
- **Öneri:** Güçlü parola politikası uygulanmalı, kritik cihazların parolaları bir parola yöneticisi (password manager) üzerinde tutulmalı ve periyodik olarak değiştirilmelidir. Cihazın desteklediği en güçlü parola saklama yöntemi kullanılmalıdır.

- **Risk Seviyesi:** Critical

Bulgu 2 - Domain Admins Grubunda Yetkisiz Kullanıcılar

- **Eksiklik:** Domain Admins grubunda 3 kullanıcı bulunduğu ve bunların içinde yönetici olmaması gereken "ayse.aksoy" ve "mehmet.kaya" gibi kullanıcıların yer aldığı görülmüştür.
- **Neden:** Yetki yönetiminin kontrolsüz yapılması ve yetkilerin düzenli olarak gözden geçirilmemesi.
- **Etkisi:** Bu hesaplardan birinin ele geçirilmesi durumunda tüm domain ortamı tehlikeye girer.
- **Öneri:** En Az Ayrıcalık (Least Privilege) prensibi uygulanmalı, gereksiz yönetici yetkileri derhal kaldırılmalı ve düzenli yetki gözden geçirmeleri yapılmalıdır.
- **Risk Seviyesi:** Critical

Bulgu 3 - Guest Hesabının Açık Olması

- **Eksiklik:** Domain Controller (DC01) üzerinde "Guest" hesabı aktif ve parolasız olarak bırakılmıştır. Bu durum, her kullanıcının kendine özel kullanıcı adı ve parola ile oturum açması gerektiğini söyleyen Bilgi Güvenliği Politikası'na aykırıdır.
- **Neden:** Varsayılan ayarların değiştirilmemesi.
- **Etkisi:** Yetkisiz kişiler anonim erişimle domain ortamına giriş yapabilir.
- **Öneri:** Guest hesabı derhal devre dışı bırakılmalı, varsayılan hesaplar düzenli olarak denetlenmelidir.
- **Risk Seviyesi:** Critical

Bulgu 4 - Audit Policy ve GPO Eksikliği

- **Eksiklik:** Politikaya uygun bir parola politikası uygulandığı ve en son geçen ay güncellendiği beyan edilmesine rağmen, parola politikasının GPO üzerinden zorunlu (enforce) kılınmadığı tespit edilmiştir. Audit Policy kapalıdır (Advanced Audit Policy yapılandırılmamıştır).
- **Neden:** Merkezi güvenlik politikalarının teknik olarak uygulanmaması.
- **Etkisi:** Kullanıcılar politikaya aykırı parolalar kullanabilir, 5 hatalı girişte kilitlenme gibi kurallar garanti edilemez. Audit kaydı olmadığı için güvenlik ihlalleri tespit edilemez ve olay sonrası inceleme yapılamaz.
- **Öneri:** Audit Policy (Advanced Audit Policy) aktif edilmeli, parola ve hesap kilitleme politikaları GPO ile enforce edilmeli, merkezi log toplama (SIEM / syslog) çözümü uygulanmalıdır.
- **Risk Seviyesi:** High

Bulgu 5 - VLAN Ayrımı Belirsizliği

- **Eksiklik:** Kablosuz ağların hangi VLAN'a bağlı olduğu net değildir. Guest ağının Developer veya Admin VLAN'ına erişim ihtimali mevcuttur. VLAN'lar arası erişim kontrol listeleri (ACL) ve firewall kuralları denetim sırasında kanıtlanamamıştır.
- **Neden:** Yanlış veya eksik VLAN yapılandırması ve ağ yapısının dokümante edilmemesi.
- **Etkisi:** Guest ağına bağlanan biri şirket içi sistemlere erişim sağlayabilir. Zayıf parolalarla birleştiğinde Admin ortamına erişilerek veri çalınabilir veya servis dışı bırakma (DoS) saldırısı yapılabilir.
- **Öneri:** VLAN segmentasyonu düzenlenmeli, Guest VLAN tamamen izole edilmeli, firewall üzerinde VLAN'lar arası erişim kuralları sıkılaştırılmalıdır. Wi-Fi ağlarına güçlü parola tanımlanmalı ve periyodik olarak değiştirilmelidir.
- **Risk Seviyesi:** High

Bulgu 6 - Güncel Olmayan Ağ Donanımı

- **Eksiklik:** Zyxel marka switch artık güncelleme almamaktadır. Cisco Catalyst 2960 switchler IOS 12.2 ile, internet sınırındaki Cisco ASA 5505 firewall ise ASA 8.2(5) sürümüyle çalışmaktadır. Diğer switchlerin firmware sürümleri de eski kalmıştır.
- **Neden:** Donanım ömrünün dolması ve ağ cihazları için yama yönetiminin yapılmaması.
- **Etkisi:** Bilinen ve yeni ortaya çıkan açıklar nedeniyle ağ cihazları, özellikle internete açık firewall, kolayca istismar edilebilir.
- **Öneri:** Eski donanımlar yenilenmeli, tüm switch ve firewall cihazları için düzenli yama yönetimi uygulanmalı ve cihaz yapılandırmaları yedeklenmelidir.
- **Risk Seviyesi:** High

6. Genel Sonuç

Denetim sonucunda Zentech Bilişim A.Ş. BT altyapısında kritik güvenlik açıkları tespit edilmiştir. Özellikle zayıf parola kullanımı, yetkisiz yönetici hesapları, açık Guest hesabı, VLAN segmentasyon eksiklikleri ve güncel olmayan cihazlar en yüksek riskleri oluşturmaktadır.

Şirketin yazılı olarak belirlediği Bilgi Güvenliği Politikası ve Parola Politikası uygulamada tam olarak yansıtılmamaktadır. Bu nedenle kısa vadede yukarıdaki önerilerin uygulanması, uzun vadede ise düzenli denetimlerin yapılması ve bilgi güvenliği farkındalık eğitimlerinin artırılması önerilmektedir. Bulguların ilgili personel tarafından öncelikli olarak ele alınması ve kapatıldığının yeniden doğrulanması gerekmektedir.

Ek-1: Denetim Öncesi Yöneltilen Sorular

Aşağıdaki sorular, denetim öncesinde eksik bilgileri tamamlamak ve denetim sürecini etkin yürütmek amacıyla Zentech Bilişim A.Ş.'ye yöneltilmiştir.

1. Ağ ve Altyapı

- Kablosuz ağların VLAN'lara dağılımı nasıl? Guest ağı Admin / Developer'a erişebiliyor mu?
- Firewall (Cisco ASA) üzerinde hangi kurallar uygulanıyor?
- İnternetten doğrudan yönetim portlarına (SSH, HTTPS) erişim var mı?
- Switch ve AP'lerin firmware sürümleri güncel mi? Yapılandırma yedeklemesi yapılıyor mu?
- Ağ cihazları için merkezi loglama veya izleme (SIEM, syslog) mevcut mu?

2. Sunucu ve Domain

- Active Directory ve sunucularda yamalar düzenli olarak uygulanıyor mu?
- Domain Controller üzerinde MFA uygulanıyor mu?
- Kullanıcı ayrıldığında hesap kapatma süreci nasıl işliyor?
- Audit Policy ve GPO ile parola politikaları gerçekten enforce ediliyor mu?
- Sunucuların yedekleme prosedürleri ve felaket kurtarma planları var mı?

3. Kullanıcı ve Erişim Yönetimi

- Domain Admin yetkileri kimlerde bulunuyor ve bunlar gerçekten gerekli mi?
- Kullanıcılar parola politikasına uygun parola kullanıyor mu?
- Yanlış girişlerde kilitleme ve hesap izleme prosedürleri uygulanıyor mu?
- Hassas bilgi erişimi sadece yetkili personelle sınırlı mı?
- Bilgi güvenliği farkındalık eğitimleri ne sıklıkta yapılıyor?

4. Politikalar ve Uyumluluk

- Bilgi Güvenliği Politikası gerçekten uygulamada mı? (Elde edilen hash çok kolay kırılmıştır.)
- USB ve harici cihaz kullanım prosedürleri uygulanıyor mu?
- Denetim ve log kontrol süreçleri periyodik olarak yapılıyor mu?
- Mevcut politikalar GDPR, ISO 27001 veya COBIT ile uyumlu mu?

5. Ek Teknik Detaylar

- Guest / Developer / Admin VLAN'ları arasında ACL mevcut mu?
- SSH, RDP gibi yönetim portları güvenli şekilde sınırlandırılmış mı?
- Antivirüs / EDR / IPS / IDS çözümleri aktif ve güncel mi?
- Zayıf parola veya varsayılan hesaplar düzenli olarak denetleniyor mu?